EXOS AEROSPACE SYSTEMS & TECHNOLOGIES, INC.

SOP-VLNSCNREM

Version 1

Generated August 13, 2026

Confidential — Internal Use Only

Table of Contents

1. Purpose
2. Scope
3. Vulnerability Scanning Using Microsoft Defender
4. Vulnerability Notification and Remediation Timelines
5. Remediation Procedure
6. System Security Alerts & Advisory Response Procedures
7. Responsibilities
8. Review and Updates

SOP-VLNSCNREM

1. Purpose

To establish a standard procedure for vulnerability scanning, notification, and remediation to ensure compliance with NIST 800-171, CMMC 2.0 Level 2, and other security standards.

2. Scope

This SOP applies to all systems, applications, and devices managed by the organization that handle Controlled Unclassified Information (CUI) or sensitive data.

3. Vulnerability Scanning Using Microsoft Defender

1. **Scanning Tool - Microsoft Defender** will be the primary tool for vulnerability scanning and continuous protection.
2. **Real-Time Protection** must be enabled across all devices to ensure continuous detection and blocking of potential threats.
3. **Scheduled Scans:**
   a. **Quick Scans:** Run at least once every week on all devices as mentioned **in Review Items**.
   b. **Full Scans:** Conducted only during significant system updates or after major incidents, as determined by the Security Administrator.
4. **Configuration Requirements:**
   a. Enable and configure Microsoft Defender to automatically download the latest threat intelligence updates when available.
   b. Ensure system notifications are configured to alert administrators to detected vulnerabilities or malware as per the reporting timings identified in Policy – Company Specific Values.
5. **Monitoring:**
   a. Use the **Microsoft Defender Security Center** to monitor the scan results and track unresolved vulnerabilities.
   b. Generate and review quarterly summaries (using the Microsoft Defender for Endpoint Export functionality) for scoped vulnerabilities to ensure the notification and remediation timelines are followed and appropriate exceptions are tracked.
6. **Exceptions:**
   a. All vulnerabilities that are installed as part of another software that is not vulnerable will be marked as exceptions in Microsoft Defender for Endpoint using Security Remediation Methodology inside Microsoft Defender for Endpoint.

b. All vulnerabilities that do not have a patch available for vulnerability within the remediation timelines will be marked as exceptions in Microsoft Defender for Endpoint for 3 months or until the remediation becomes available

i. After an age of 6 months, if there is no remediation available, work with the *Security Admin* to perform manual remediation as possible, or extend the exception timeline.

4. Vulnerability Notification and Remediation Timelines

Severity Level	Notification Timeline	Remediation Timeline
Critical	Real-time	Within 30 days
High	Within 7 days	Within 30 days
Medium	Within 30 days	Within 60 days
Low	Within 90 days	Within 120 days

5. Remediation Procedure

1. **Notification:**

a. The **Security Administrator** will notify affected users about detected vulnerabilities. Notifications will include:

i. Vulnerability name and description.

ii. Affected systems and their risk level.

iii. Required actions for remediation based on severity.

2. **User-Initiated Remediation:**

a. Users are encouraged to take appropriate actions to remediate vulnerabilities if possible. Examples include:

i. Installing pending software updates.

ii. Applying patches to applications or systems.

iii. Reconfiguring settings as per provided instructions.

b. Automox patch management software will deploy automatic patches to third-party applications when available.

3. **Involvement of Security Administrator:**

a. If the user is unable to perform the required updates:

i. The user must immediately inform the Security Administrator for further assistance.

ii. The Security Administrator will perform the remediation tasks on behalf of the user or guide the user through the process.

4. **Process Flow:**
   a. **Identification:**
      - Vulnerabilities are detected during routine scans or incident response activities.
   b. **Notification:**
      - Users are informed within the specified notification timeline, based on severity.
   c. **Action:**
      - Users either resolve the issue independently or request support from the Security Administrator for vulnerabilities that are not automatically patched using Automox patch management software.
   d. **Verification:** Follow-up scans confirm the resolution of the vulnerability.
   e. **Escalation:** If remediation is delayed beyond the specified timeline:
      - **Critical Vulnerabilities:** Escalate to the Security Admin immediately.
      - **High Vulnerabilities:** Escalate to the Security Admin immediately.
      - **Medium/Low Vulnerabilities:** Highlight during quarterly compliance reviews.

6. System Security Alerts & Advisory Response Procedures

6.1. Review of Security Alerts and Advisories

The *Security Admin* shall review all system-generated security alerts and vendor advisories like CISA, Microsoft.

6.2. Identification and Classification of Alerts

Upon receipt of an alert or advisory, the *Security Admin* shall review and classify it according to severity, potential impact, and relevance to in-scope systems. Alerts must be categorized as per their severity:

- **Critical**
- **High**
- **Medium**
- **Low**

6.3. Required Response Actions

For each alert or advisory, appropriate response actions must be identified, documented, and executed. Response actions may include, but are not limited to:

- Implementing patches or updates
-

Applying configuration changes or compensating controls

- Blocking malicious IPs, domains, or signatures
- Isolating affected systems from the network
- Increasing logging or enabling additional monitoring
- Conducting targeted vulnerability scans
- Initiating an incident response process if malicious activity is confirmed

6.4. Documentation

All alerts, classifications, and associated response actions must be approved as per Change Management if any response actions are taken.

6.5. Verification and Closure

After remediation, the *Security Admin* shall verify that corrective measures were successfully applied and that the alert condition is resolved and mark the Change Management complete. Verification may include rescanning, log review, or system validation.

7. Responsibilities

1. **Security Administrator:**
   - Configure and maintain Microsoft Defender.
   - Schedule and monitor vulnerability scans.
   - Audit scanning records for compliance with organizational policies.
   - Notify users of vulnerabilities and provide remediation guidance.
   - Manage exceptions and update exceptions.
   - Perform remediation for users unable to address the vulnerabilities themselves.
   - Assist Company Admin deploy Automox patch management software for automatic patching of third-party software vulnerabilities where patches have been released.
2. **Users:**
   - Ensure compliance with scan schedules.
   - Resolve vulnerabilities detected during scans.
   - Act on notifications and address vulnerabilities as instructed.

   Communicate promptly with the *Security Administrator* if assistance is required.

8. Review and Updates

- This SOP will be reviewed annually or when significant changes occur in the organization's vulnerability management practices.

Revision History

Version	Date	Author	Change Summary
v1	Aug 11, 2026	nathaniel@atomus-cyber.com	Initial publication of "SOP-VLNSCNREM".

Acknowledgement & Signature

By signing below, the undersigned acknowledges that the contents of SOP-VLNSCNREM (Version 1) have been reviewed and approved on behalf of Exos Aerospace Systems & Technologies, Inc..

Point of Contact

NAME

Jquinn

TITLE

Chief Executive Officer, Co-Founder

SIGNATURE

DATE

Aug 13, 2026

Signed electronically on Aug 13, 2026